PAZ, JUSTICIA E INSTITUCIONES SÓLIDAS

Casos de Abuso y Gestión de Riesgos

GastoTransparente Municipal — plataforma de transparencia y seguimiento del gasto público municipal.

Septiembre 2026

Agenda

01 Contexto y requisitos de seguridad

02 Casos de abuso

03 Plan de pruebas de seguridad

04 Conclusiones y próximos pasos

Contexto del Proyecto

Qué es la plataforma

Sistema web público para visualizar, consultar y descargar información sobre el presupuesto y gasto municipal, de modo que ciudadanos, periodistas y organizaciones puedan fiscalizar el uso de fondos públicos en tiempo real.

Por qué es sensible

Los datos son de carácter público, pero de alto riesgo de manipulación por actores políticos o económicos. La plataforma opera en un contexto de alto escrutinio público constante.

"Un incidente de seguridad no es solo un problema técnico: es una crisis institucional con impacto en la democracia municipal."

Atributos de Seguridad Clave

Integridad
Control de versiones auditable de cada registro publicado.

Disponibilidad
Alta disponibilidad ante ataques DDoS en períodos electorales.

Confidencialidad
Protección de documentos internos antes de su publicación.

Trazabilidad
Log inmutable de todas las modificaciones con firma digital.

Autenticidad
Firma digital de funcionarios en los datos publicados.

Requisitos de Seguridad



Requisitos de Seguridad — RS-01 a RS-06

RS-01 Funcional

Autenticación Multifactor (MFA)

Previene accesos no autorizados aunque las credenciales sean comprometidas por phishing o fuerza bruta.

RS-02 No Funcional

Cifrado de Datos en Reposo y Tránsito

Garantiza confidencialidad e integridad ante accesos no autorizados a la infraestructura.

RS-03 Funcional

Registro de Auditoría Inmutable

Permite trazabilidad completa de cambios y detecta manipulaciones de datos públicos.

RS-04 No Funcional

Protección Anti-DDoS y Rate Limiting

Un DDoS en período electoral puede silenciar la rendición de cuentas.

RS-05 Funcional

Control de Acceso Basado en Roles (RBAC)

Limita el radio de acción de credenciales comprometidas.

RS-06 Funcional

Firma Digital de Registros Presupuestales

Garantiza autenticidad e impide la repudiación de cambios.

Requisitos de Seguridad — RS-07 a RS-13

RS-07 No Funcional

Expiración de Sesión por Inactividad

Reduce la ventana de explotación de sesiones abiertas.

RS-08 Funcional

Validación y Sanitización de Entradas

Bloquea las técnicas de inyección más comunes del OWASP Top 10.

RS-09 No Funcional

Política de Contraseñas y Bloqueo de Cuenta

Mitiga fuerza bruta y credential stuffing.

RS-10 Funcional

Notificaciones de Seguridad en Tiempo Real

Reduce el tiempo medio de detección (MTTD).

RS-11 Funcional

Validación Estricta de JWT (Algoritmo Fijo)

Cierra CA-11: rechaza tokens con alg:'none' o algorithm confusion.

RS-12 Funcional

Atomicidad y Locks en Aprobación Dual

Previene race conditions en la doble firma de contratos (CA-12).

RS-13 No Funcional

Correlación Multi-Vector SIEM con Baseline

Detecta ataques que se mantienen bajo el umbral individual de cada señal (CA-13).

Casos de Abuso



Manipulación Interna y Ataques de Disponibilidad

CRÍTICO

CA-01 — Manipulación de Registros Presupuestales

- **Atacante:** Funcionario municipal con acceso editor
- **Objetivo:** Alterar montos de contratos para ocultar desviación de fondos
- **Impacto:** Pérdida de integridad de datos públicos y encubrimiento de corrupción
- Log de auditoría append-only con firma digital
- Workflow de aprobación dual para cambios críticos

Probabilidad Alta · Impacto Alto · Nivel CRÍTICO

CRÍTICO

CA-02 — DDoS durante Rendición de Cuentas Electoral

- **Atacante:** Grupo político adversario o actor externo
- **Objetivo:** Silenciar la plataforma en momentos de alta visibilidad pública
- **Impacto:** Indisponibilidad del servicio en período crítico; daño a la confianza pública
- CDN con protección DDoS (Cloudflare/AWS Shield)
- Rate limiting por IP, token y geolocalización

Probabilidad Alta · Impacto Alto · Nivel CRÍTICO

Inyección de Código en la Interfaz Pública

ALTO

CA-03 — Inyección SQL en Buscador de Contratos

- **Atacante:** Atacante externo con conocimiento técnico
- **Objetivo:** Extraer datos confidenciales o eliminar registros de la base
- **Impacto:** Exposición de credenciales y documentos pre-publicación
- ORM con consultas parametrizadas
- WAF con reglas OWASP

Probabilidad Media · Impacto Alto · Nivel ALTO

ALTO

CA-04 — XSS Persistente en Comentarios Ciudadanos

- **Atacante:** Ciudadano malintencionado o actor político
- **Objetivo:** Robar sesiones de administradores o inyectar desinformación
- **Impacto:** Toma de control de cuenta admin; desinformación visible a ciudadanos
- Sanitización de salida HTML (DOMPurify/CSP)
- Tokens de sesión HttpOnly y Secure

Probabilidad Media · Impacto Alto · Nivel ALTO

Suplantación de Identidad y Acceso Indebido

CRÍTICO

CA-05 — Suplantación de Funcionario (Phishing)

- **Atacante:** Externo con acceso a email corporativo comprometido
- **Objetivo:** Publicar datos falsos haciéndose pasar por un funcionario
- **Impacto:** Datos falsos publicados como oficiales; crisis de confianza
- MFA obligatorio (TOTP o FIDO2)
- Análisis de comportamiento de login por IP/país

Probabilidad Alta · Impacto Alto · Nivel CRÍTICO

ALTO

CA-06 — Acceso No Autorizado a Reportes (IDOR)

- **Atacante:** Ciudadano o periodista con acceso básico
- **Objetivo:** Acceder a informes de auditoría antes de su publicación oficial
- **Impacto:** Filtración de datos de auditoría; uso político de información
- UUIDs no predecibles en lugar de IDs secuenciales
- Verificación de permisos en cada solicitud

Probabilidad Media · Impacto Medio · Nivel ALTO

Fuerza Bruta y Alteración del Portal

ALTO

CA-07 — Fuerza Bruta sobre Cuentas de Auditores

- **Atacante:** Atacante automatizado (script/bot)
- **Objetivo:** Obtener acceso privilegiado mediante ataque de diccionario
- **Impacto:** Compromiso de cuenta de auditor y acceso a datos internos
- Bloqueo de IP tras 5 intentos con CAPTCHA
- MFA como segunda barrera

Probabilidad Alta · Impacto Alto · Nivel ALTO

ALTO

CA-08 — Defacement del Portal Público

- **Atacante:** Hacktivista o grupo de presión política
- **Objetivo:** Alterar la apariencia del portal para difundir desinformación
- **Impacto:** Daño reputacional severo; posible infección de visitantes
- WAF + IDS/IPS con detección de cambios en archivos
- Despliegues inmutables (CI/CD)

Probabilidad Media · Impacto Alto · Nivel ALTO

Exfiltración de Datos y Archivos Maliciosos

MEDIO

CA-09 — Exfiltración Masiva vía API sin Paginación

- **Atacante:** Competidor, lobbyist o actor con interés económico
- **Objetivo:** Descargar toda la base de contratos para análisis privado
- **Impacto:** Uso comercial no autorizado; posible identificación para soborno
- Rate limiting por token (máx. 100 req/min)
- Paginación obligatoria con límite de resultados

Probabilidad Alta · Impacto Medio · Nivel MEDIO

ALTO

CA-10 — Carga de Documentos Maliciosos

- **Atacante:** Funcionario comprometido o atacante con acceso editor
- **Objetivo:** Alojar malware en el servidor como documento oficial
- **Impacto:** Infección masiva de ciudadanos; responsabilidad legal del municipio
- Análisis antivirus en tiempo real (ClamAV)
- Sandbox de documentos antes de publicación

Probabilidad Baja · Impacto Alto · Nivel ALTO

Escalada de Privilegios y Manipulación de Lógica de Negocio

CRÍTICO · NUEVO

CA-11 — Escalada de Privilegios por JWT (Algorithm Confusion)

- **Atacante:** Ciudadano técnico con conocimiento de criptografía JWT
- **Objetivo:** Elevar privilegios de Ciudadano a Administrador cambiando el rol en el token
- **Impacto:** Compromiso total del RBAC; un ciudadano opera como Admin

- jwt.verify() con algoritmo fijo ({algorithms:['HS256']})
- Verificación del rol real en BD en cada endpoint

Probabilidad Alta · Impacto Alto · Nivel CRÍTICO · genera RS-11

ALTO · NUEVO

CA-12 — Race Condition en Aprobación Dual de Contratos

- **Atacante:** Funcionario Editor con herramientas de automatización básica
- **Objetivo:** Aprobar un contrato fraudulento con una sola firma burlando la doble aprobación
- **Impacto:** Contrato fraudulento aprobado; el log registra el fraude pero no lo impide

- SELECT FOR UPDATE + idempotency key de un solo uso
- Alerta SIEM ante dos aprobaciones en menos de 5 segundos

Probabilidad Media · Impacto Alto · Nivel ALTO · genera RS-12

Exfiltración Encubierta Multi-Vector

CRÍTICO · NUEVO

CA-13 — IDOR + API Scraping Correlacionado

- **Atacante:** Periodista técnico con token ciudadano y scripts Python
- **Objetivo:** Descargar informes internos no publicados antes de su publicación oficial
- **Impacto:** Filtración de auditorías pre-publicación sin disparar ninguna alerta individual
- Borradores accesibles solo para Auditor/Admin
- Correlación multi-vector SIEM: mismo token, múltiples endpoints en 30 min

Probabilidad Alta · Impacto Alto · Nivel CRÍTICO · genera RS-13

Gap identificado

CA-06 (IDOR) y CA-09 (exfiltración vía API) se modelaron como amenazas independientes. El SIEM monitorea señales individuales pero no las correlaciona: un atacante que se mantiene bajo el umbral de cada señal por separado no dispara ninguna alerta.

Los tres casos del stress test (CA-11, CA-12, CA-13) generan los requisitos RS-11, RS-12 y RS-13.

Plan de Pruebas



Auditoría Interna y Resiliencia ante DDoS

CRÍTICO

CA-01 — Registros Presupuestales

Objetivo
Verificar que el log de auditoría registra toda modificación de registros presupuestales

Procedimiento
Editar un contrato y confirmar que el cambio queda registrado con usuario, timestamp y hash anterior

Resultado esperado
Entrada inmutable en el log con firma digital; alerta enviada al supervisor

Criterio de éxito
El log no puede ser borrado ni editado por el mismo usuario que hizo el cambio

CRÍTICO

CA-02 — Resistencia a DDoS

Objetivo
Evaluar la resistencia del sistema a un ataque DDoS simulado

Procedimiento
Enviar 10.000 solicitudes/min durante 5 minutos con JMeter contra el buscador

Resultado esperado
Respuesta <3s para el 95% de usuarios legítimos; IPs atacantes bloqueadas

Criterio de éxito
No hay caída total del servicio; el rate limiter actúa en menos de 10s

Inyección SQL y Scripts en Comentarios

ALTO

CA-03 — Inyección SQL

Objetivo
Detectar vulnerabilidades de inyección SQL en el buscador de contratos

Procedimiento
SQLMap y payloads manuales (' OR '1'='1'--, UNION SELECT) en todos los campos

Resultado esperado
El sistema rechaza las entradas con HTTP 400; no retorna información de la base

Criterio de éxito
Cero consultas SQL no parametrizadas ejecutadas; el WAF registra el intento

ALTO

CA-04 — Scripts en Comentarios

Objetivo
Verificar que el sistema neutraliza scripts maliciosos en comentarios

Procedimiento
Insertar <script>alert(1)</script> y payloads de exfiltración en comentarios

Resultado esperado
El script no se ejecuta; la salida aparece como texto plano o es eliminada

Criterio de éxito
La CSP bloquea la ejecución; los tokens no son accesibles vía JS

Verificación de MFA y Control de Acceso

CRÍTICO

CA-05 — MFA ante Phishing

Objetivo
Verificar que el MFA bloquea el acceso con credenciales robadas

Procedimiento
Con usuario y contraseña válidos, intentar login sin el segundo factor

Resultado esperado
El sistema deniega el acceso y solicita el segundo factor

Criterio de éxito
Imposible autenticarse con solo usuario y contraseña desde IP no reconocida

ALTO

CA-06 — IDOR en Documentos

Objetivo
Detectar vulnerabilidades IDOR en endpoints de documentos

Procedimiento
Modificar el UUID en URLs de reportes internos con Burp Suite

Resultado esperado
HTTP 403 Forbidden para cualquier documento sin permiso explícito

Criterio de éxito
Cero accesos exitosos a recursos no autorizados; todo queda registrado

Resistencia a Fuerza Bruta y Manipulación del Portal

ALTO

CA-07 — Fuerza Bruta

Objetivo
Verificar que el sistema bloquea ataques de fuerza bruta

Procedimiento
Hydra con 1.000 contraseñas comunes contra el login de un auditor

Resultado esperado
La cuenta se bloquea tras 5 intentos fallidos; se activa CAPTCHA

Criterio de éxito
Menos del 0.1% de los intentos resulta en un login exitoso

ALTO

CA-08 — Integridad del Portal

Objetivo
Detectar modificaciones no autorizadas en archivos del portal

Procedimiento
Modificar un archivo JS de la página principal directamente en el servidor

Resultado esperado
Alerta generada en menos de 60 segundos; restauración automática

Criterio de éxito
El sistema de integridad detecta el cambio y notifica al equipo

Límites de la API y Validación de Archivos

MEDIO

CA-09 — Rate Limiting de la API

Objetivo
Verificar que el rate limiting protege contra exfiltración masiva vía API

Procedimiento
Con un token legítimo, hacer 500 llamadas a /api/contratos en 1 minuto

Resultado esperado
El sistema devuelve HTTP 429 a partir de la solicitud 101

Criterio de éxito
El límite se aplica correctamente; las solicitudes excedentes no retornan datos

ALTO

CA-10 — Validación de Archivos

Objetivo
Verificar que el sistema rechaza archivos maliciosos en la carga

Procedimiento
Subir archivos .exe, .php, .docx con macro y PDF con JavaScript embebido

Resultado esperado
El sistema rechaza los archivos no permitidos con mensaje de error

Criterio de éxito
Solo se aceptan extensiones de lista blanca; el antivirus detecta los archivos de prueba

Validación de JWT y Concurrencia en Aprobaciones

CRÍTICO

CA-11 — Algorithm Confusion en JWT

Objetivo
Verificar que el servidor rechaza tokens con algoritmo alterado o sin firma

Procedimiento
Con Burp Suite, cambiar alg de RS256 a HS256 usando la clave pública como secreto, y modificar "role" a "admin"

Resultado esperado
HTTP 401 ante el token forjado; el endpoint /admin no responde

Criterio de éxito
jwt.verify() con algoritmo fijo bloquea el 100% de los tokens forjados

ALTO

CA-12 — Concurrencia en Aprobación Dual

Objetivo
Verificar que la aprobación dual resiste condiciones de carrera

Procedimiento
Lanzar 50 solicitudes concurrentes al mismo endpoint de aprobación con el mismo token

Resultado esperado
Solo una solicitud se procesa; el resto recibe HTTP 409

Criterio de éxito
Cero aprobaciones duplicadas registradas en la base de datos

Correlación Multi-Vector en el SIEM

CRÍTICO

CA-13 — Exfiltración Multi-Vector

Objetivo
Verificar que el SIEM detecta accesos combinados bajo el umbral individual

Procedimiento
Con un token ciudadano, descargar 1-3 reportes en estado borrador por minuto durante 40 minutos

Resultado esperado
Acceso denegado a borradores; alerta SIEM al superar 10 documentos únicos/hora

Criterio de éxito
La correlación multi-vector detecta el patrón aunque cada señal esté bajo su umbral individual

Conclusiones



Resumen del Análisis

10 **Requisitos de seguridad**
Autenticación, cifrado, trazabilidad, disponibilidad e integridad de datos.

13 **Casos de abuso identificados**
10 del modelo original más CA-11, CA-12 y CA-13 del stress test.

5 **Casos críticos priorizados**
CA-01, CA-02, CA-05, CA-11 y CA-13 requieren mitigación inmediata.

10 **Pruebas de seguridad**
Cada una con procedimiento, resultado esperado y criterio de éxito verificable.

Principio aplicado: modelar amenazas desde la perspectiva del atacante para fortalecer las defensas antes del despliegue.

Hoja de Ruta de Implementación

Fase 1

Fundamentos de acceso

MFA (TOTP o FIDO2), control de acceso por roles (RBAC) y cifrado en tránsito y en reposo.

Fase 2

Trazabilidad y auditoría

Log de auditoría inmutable con firma digital y workflow de aprobación dual para cambios críticos.

Fase 3

Resiliencia de la plataforma

CDN con protección anti-DDoS, WAF con reglas OWASP y rate limiting por token e IP.

Fase 4

Validación continua

Pipeline CI/CD con despliegues inmutables y el plan de pruebas de seguridad de forma recurrente.

Identidad y acceso

MFA · TOTP/FIDO2 | RBAC

Perímetro y disponibilidad

Cloudflare / AWS Shield | WAF OWASP

Datos y almacenamiento

ORM parametrizado | Cifrado AES-256 / TLS

Integridad y contenido

Firma digital | DOMPurify / CSP | ClamAV

GASTOTRANSPARENTE MUNICIPAL

Gracias por su atención

Preguntas y comentarios son bienvenidos.

Septiembre 2026